解決方案FlexPod

FlexPod

NetApp
May 17, 2022

This PDF was generated from https://docs.netapp.com/zh-tw/flexpod/security/security-ransomware_what_is_ransomware.html on May 17, 2022. Always check docs.netapp.com for the latest.

目錄

解決方案FlexPod . . . 1
TR-4802：FlexPod 《勒索軟體解決方案》 . . . 1
概述FlexPod . . . 3
勒索軟體保護措施 . . . 4
保護FlexPod 及恢復資料 . . . 6
無需支付贖金即可繼續營運 . . . 19
結論 . . . 19
感謝 . . . 19
其他資訊 . . . 20

解決方案FlexPod

TR-4802：FlexPod 《勒索軟體解決方案》

Arvind Ramakrishnan、NetApp

與下列合作夥伴合作：

若要瞭解勒索軟體、必須先瞭解密碼編譯的幾個關鍵點。Cryptographical方法可利用共享的秘密金鑰（對稱金鑰加密）或一對金鑰（非對稱金鑰加密）來加密資料。其中一個金鑰是廣泛使用的公開金鑰、另一個是未揭露的私密金鑰。

勒索軟體是一種以密碼學為基礎的惡意軟體、這是使用密碼編譯來建置惡意軟體。此惡意軟體可同時使用對稱和非對稱金鑰加密來鎖定受害者的資料、並要求贖金提供金鑰來解密受害者的資料。

勒索軟體如何運作？

下列步驟說明勒索軟體如何使用密碼編譯來加密受害者的資料、而不需讓受害者有任何解密或恢復空間：

1. 攻擊者會產生金鑰配對、如同非對稱金鑰加密。產生的公開金鑰會放在惡意軟體中、然後再發行惡意軟體。
2. 惡意軟體進入受害者的電腦或系統後、會使用pseudorandom號碼產生器（PRNG）或任何其他可行的隨機數字產生演算法、產生隨機對稱金鑰。
3. 惡意軟體使用此對稱金鑰來加密受害者的資料。最後會使用內嵌於惡意軟體中的攻擊者公開金鑰來加密對稱金鑰。此步驟的輸出為加密對稱金鑰的非對稱加密文字、以及受害者資料的對稱加密文字。
4. 惡意軟體會將受害者的資料和用於加密資料的對稱金鑰歸零（清除）、因此無法進行還原。
5. 受害者現在會看到對稱金鑰的非對稱加密文字、以及必須支付的贖金值、以便取得用於加密資料的對稱金鑰。
6. 受害者支付贖金、並與攻擊者分享非對稱加密文字。攻擊者使用自己的私密金鑰來解密密碼文字、這會導致對稱金鑰。
7. 攻擊者與受害者共用此對稱金鑰、可用來解密所有資料、進而從攻擊中恢復。

挑戰

受到勒索軟體攻擊時、個人和組織會面臨下列挑戰：

- 最重要的挑戰是、組織或個人的生產力必須立即大幅提高。恢復正常狀態需要時間、因為所有重要檔案都必須重新取得、而且系統必須受到保護。
- 這可能導致資料外洩、其中包含屬於客戶或客戶的敏感機密資訊、並導致組織顯然想要避免的危機情況。
- 資料可能會落入不法之手或被完全刪除、這會導致無法回報的情況、對組織和個人而言可能是災難性的。
- 支付贖金之後、無法保證攻擊者會提供金鑰來還原資料。
- 無法保證攻擊者不會在支付贖金的情況下廣播敏感資料。

- 在大型企業中、找出導致勒索軟體攻擊的漏洞是一項繁瑣的工作、而保護所有系統的安全則需要付出許多努力。

誰有風險？

任何人都可能遭受勒索軟體攻擊、包括個人和大型組織。未實作明確定義的安全措施和實務做法的組織、更容易遭受此類攻擊。攻擊對大型組織的影響可能比個人承受的影響大幾倍。

勒索軟體約佔所有惡意軟體攻擊的28%。換句話說、四分之一以上的惡意軟體事件是勒索軟體攻擊。勒索軟體可透過網際網路自動且不加區分地散佈、一旦發生安全性問題、便可進入受害者的系統、繼續散佈到其他連線系統。攻擊者傾向於鎖定執行大量檔案共用、擁有大量敏感和關鍵資料的人員或組織、或是維持不適當的保護措施來防範攻擊。

攻擊者傾向專注於下列潛在目標：

- 大學與學生社群
- 政府辦公室與機構
- 醫院
- 銀行

這並非詳盡的目標清單。如果您不屬於這些類別、就無法安全防範攻擊。

勒索軟體如何進入系統或擴散？

勒索軟體可透過多種方式進入系統或擴散至其他系統。在當今世界中、幾乎所有系統都透過網際網路、LAN、WAN等方式彼此連線。在這些系統之間產生和交換的資料量只會增加。

勒索軟體的一些最常見傳播方式、包括我們每天用來共用或存取資料的方法：

- 電子郵件
- 點對點網路
- 檔案下載
- 社交網路
- 行動裝置
- 連線至不安全的公共網路
- 存取Web URL

資料遺失的後果

資料遺失的後果或影響可能比組織預期的影響更廣泛。影響可能會因停機時間或組織無法存取其資料的期間而有所不同。攻擊持續時間越長、對組織的營收、品牌和聲譽的影響就越大。組織也可能面臨法律問題、生產力大幅下降。

隨著這些問題持續不斷、它們開始擴大、最終可能改變組織的文化、視其對攻擊的回應方式而定。在當今世界中、資訊快速傳播、以及有關組織的負面新聞、可能會對組織的聲譽造成永久性損害。組織可能面臨資料遺失的重大損失、最終可能導致企業倒閉。

財務影響

根據最近的資料 "McAfee報告"全球網路犯罪所造成的成本約為6、000億美元、約佔全球國內生產總值的0.8%。如果將這筆金額與全球不斷成長的4.2兆美元網際網路經濟進行比較、則相當於14%的成長稅。

勒索軟體在這筆財務成本中佔有相當大的比例。2018年、勒索軟體攻擊所造成的成本約為80億美元、預計2019年將達到115億美元。

解決方案為何？

只有實作主動式災難恢復計畫、才能在停機時間最短的情況下、從勒索軟體攻擊中恢復。從攻擊中恢復的能力很好、但完全預防攻擊是理想的做法。

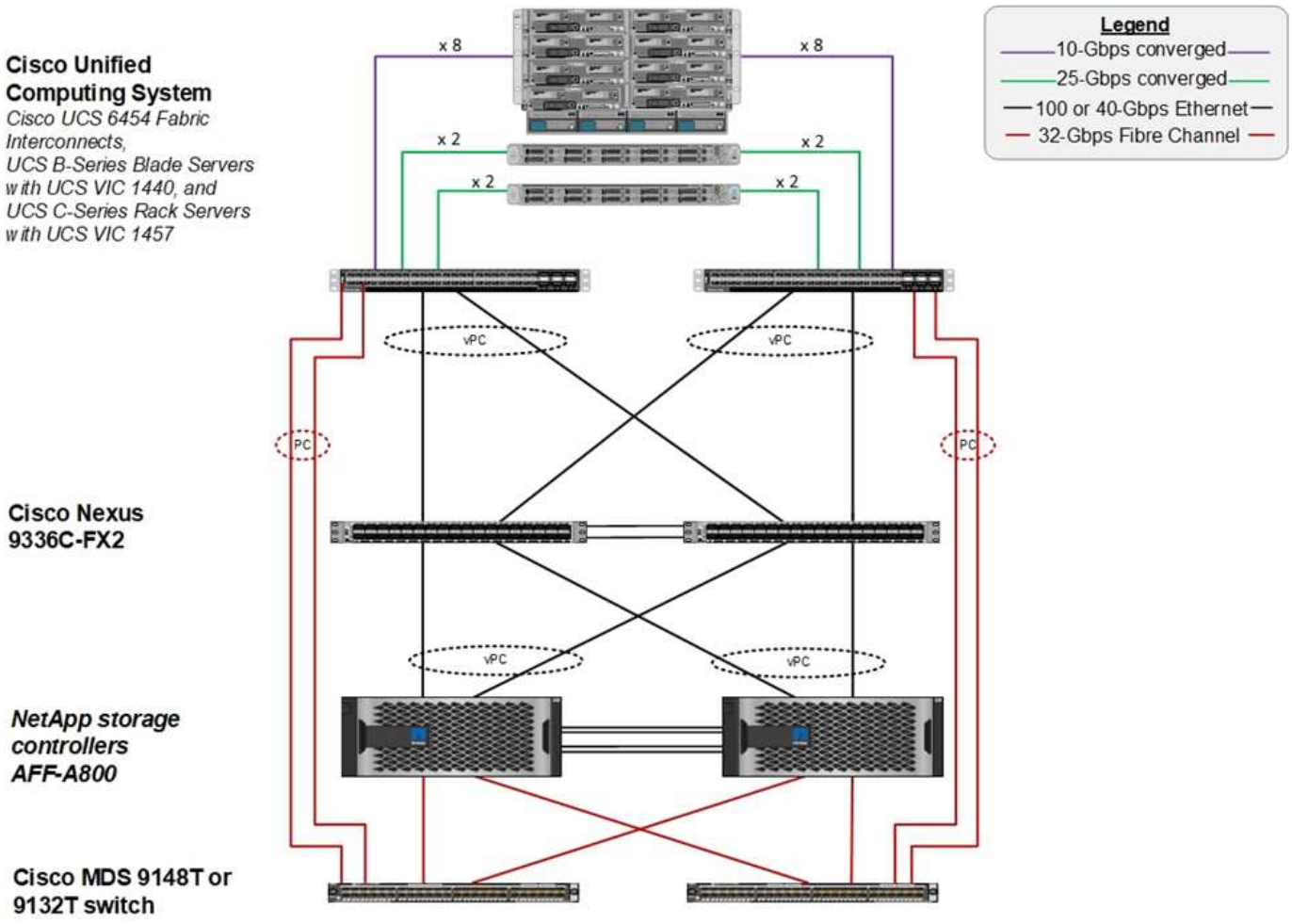
雖然您必須從幾個方面進行審查和修正、以防止攻擊、但讓您預防或恢復攻擊的核心元件是資料中心。

資料中心的設計及其提供的保護網路、運算和儲存端點的功能、在打造安全環境以利日常營運方面扮演著關鍵角色。本文說明FlexPod 了在發生攻擊時、使用混合雲基礎架構的功能如何協助快速恢復資料、也有助於完全預防攻擊。

概述FlexPod

NetApp是一種預先設計、整合及驗證的架構、將Cisco Unified Computing System（Cisco UCS）伺服器、Cisco Nexus系列交換器、Cisco MDS架構交換器及NetApp儲存陣列、整合為單一靈活架構。FlexPod支援各種工作負載的支援、可在不發生單點故障的情況下、維持成本效益和設計靈活度、實現高可用度。FlexPod支援不同Hypervisor和裸機伺服器的支援功能、也可根據客戶工作負載需求調整規模及最佳化。FlexPod

下圖說明FlexPod 了這個架構、並清楚強調堆疊所有層級的高可用度。儲存設備、網路和運算的基礎架構元件的設定方式、可在其中一個元件故障時、立即將作業容錯移轉至正常合作夥伴。



這個系統的主要優勢FlexPod 在於它是針對數個工作負載預先設計、整合及驗證的系統。每項解決方案驗證都會發佈詳細的設計與部署指南。這些文件包括您必須採用的最佳實務做法、讓工作負載能夠順暢地在FlexPod 運轉於整個過程中。這些解決方案是以同級最佳的運算、網路和儲存產品打造而成、並提供多項功能、著重於整個基礎架構的安全性和強化。

"IBM的X-Force威脅情報索引" 「造成三分之二的資料外洩事件的人為錯誤、包括錯誤設定的雲端基礎架構中歷史記錄的增加率達420%。」

有了NetApp驗證系統、您就能透過Ansible教戰手冊、根據Cisco驗證設計（CVD）和NetApp驗證架構（NVA）中所述的最佳實務做法、執行基礎架構的端點對端點設定、避免誤用基礎架構。FlexPod

勒索軟體保護措施

本節將討論NetApp ONTAP VMware資料管理軟體的主要功能、以及Cisco UCS和Cisco Nexus工具、您可以使用這些工具來有效保護和恢復勒索軟體攻擊。

儲存設備：ONTAP NetApp

支援資料保護的功能眾多、大部分免費提供給使用此系統的客戶。ONTAP ONTAP您可以隨時使用下列功能來保護資料免受攻擊：

- * NetApp Snapshot技術。* Snapshot複本是磁碟區的唯讀映像、可在某個時間點擷取檔案系統的狀態。這些複本有助於保護資料、不會影響系統效能、同時也不會佔用大量的儲存空間。NetApp建議您建立建

立Snapshot複本的建立排程。您也應該維持較長的保留時間、因為某些惡意軟體可能會處於休眠狀態、然後在感染後的數週或數月內重新啟動。發生攻擊時、可以使用感染前所取得的Snapshot複本來復原磁碟區。

- * NetApp SnapRestore 支援技術。* SnapRestore 支援資料還原軟體對於從資料毀損中恢復或僅回復檔案內容非常實用。不還原磁碟區的屬性；它比系統管理員將檔案從Snapshot複本複製到作用中檔案系統所能達到的速度快得多。SnapRestore當許多檔案必須儘快恢復時、資料的恢復速度很有幫助。一旦發生攻擊、這項高效率的恢復程序有助於企業迅速恢復上線。

- * NetApp SnapCenter 功能* SnapCenter 。* Ses庫 軟體使用NetApp儲存型備份與複寫功能、提供應用程式一致的資料保護。此軟體可與企業應用程式整合、並提供應用程式專屬及資料庫專屬的工作流程、以滿足應用程式、資料庫及虛擬基礎架構管理員的需求。支援易於使用的企業平台、可安全地協調及管理應用程式、資料庫和檔案系統之間的資料保護。SnapCenter在資料恢復期間、提供應用程式一致的資料保護功能至關重要、因為它能讓您更快將應用程式還原至一致的狀態。

- * NetApp SnapLock 支援技術* SnapLock 。*支援特殊用途磁碟區、可將檔案儲存並承諾為不可刪除、不可重複寫入的狀態。使用者的資料駐留FlexVol 在一個支援的地方、可透過SnapLock NetApp SnapMirror 或SnapVault 支援技術分別鏡射或保存到一個支援的地方。在保留期間結束之前、無法刪除位於現象磁碟區中的檔案SnapLock 、磁碟區本身及其託管Aggregate。

- * NetApp FPolicy技術。*使用FPolicy軟體、禁止對具有特定副檔名的檔案執行作業、以防止攻擊。可針對特定檔案作業觸發FPolicy事件。此事件與原則有關、該原則會呼叫IT需要使用的引擎。您可以使用一組可能含有勒索軟體的副檔名來設定原則。當副檔名不允許的檔案嘗試執行未獲授權的作業時、FPolicy會防止該作業執行。

網路：Cisco Nexus

Cisco NX OS軟體支援NetFlow功能、可增強偵測網路異常狀況與安全性。NetFlow會擷取網路上每個對話的中繼資料、通訊相關各方、使用的傳輸協定、以及交易持續時間。在彙總和分析資訊之後、即可深入瞭解正常行為。

收集到的資料也能辨識可疑的活動模式、例如惡意軟體散佈於整個網路、否則可能無法察覺。

NetFlow使用流程來提供網路監控的統計資料。流程是一種單向封包串流、傳入來源介面（或VLAN）、金鑰的值相同。金鑰是封包內欄位的識別值。您可以使用流程記錄來建立流程、以定義流程的獨特按鍵。您可以使用流程匯出器、將NetFlow為流程收集的資料匯出至遠端NetFlow收集器、例如Cisco Stealthwatch。Stealthwatch會使用此資訊持續監控網路、並在發生勒索軟體疫情時提供即時威脅偵測和事件回應證明。

運算：Cisco UCS

Cisco UCS是FlexPod 架構中的運算端點。您可以使用多種Cisco產品、在作業系統層級保護堆疊的這一層。

您可以在運算或應用程式層中實作下列主要產品：

- *適用於端點的Cisco進階惡意軟體保護（AMP）。*此解決方案支援Microsoft Windows與Linux作業系統、整合了預防、偵測與回應功能。此安全軟體可防止資料外洩、在進入點封鎖惡意軟體、並持續監控及分析檔案與處理活動、以快速偵測、控制及補救可能規避第一線防禦的威脅。

  AMP的惡意活動保護（MAP）元件會持續監控所有端點活動、並提供執行時間偵測、並封鎖端點上執行中程式的異常行為。例如、當端點行為顯示勒索軟體時、會終止違規的程序、以防止端點加密並停止攻擊。

- * Cisco進階的電子郵件安全惡意軟體保護。*電子郵件已成為散佈惡意軟體及進行網路攻擊的主要工具。平均而言、每天大約會交換1000億封電子郵件、讓攻擊者能夠在使用者的系統中擁有絕佳的滲透率。因此、防禦這類攻擊是絕對必要的。

  擴大分析電子郵件中的威脅、例如零時差攻擊、以及隱藏在惡意附件中的惡意軟體。它也使用領先業界

的URL情報來對抗惡意連結。它能為使用者提供進階保護、防止針對性網頁仿冒、勒索軟體及其他複雜的攻擊。

- 新一代入侵防禦系統（**NGIPS**）。 Cisco火力NGIPS可部署為資料中心的實體應用裝置、或部署為VMware上的虛擬應用裝置（NGIPSv for VMware）。這套高效率的入侵防禦系統可提供可靠的效能、並降低總體擁有成本。您可以選擇訂閱授權來擴充威脅保護、以提供擴大的應用程式可見度與控制能力、以及URL篩選功能。虛擬化的NGIPS會檢查虛擬機器（VM）之間的流量、並使在資源有限的站台上部署及管理NGIPS解決方案變得更容易、同時增加實體與虛擬資產的保護。

保護**FlexPod** 及恢復資料

本節說明當攻擊發生時、如何恢復終端使用者的資料、以及如何使用FlexPod 一套系統來防止攻擊。

測試床總覽

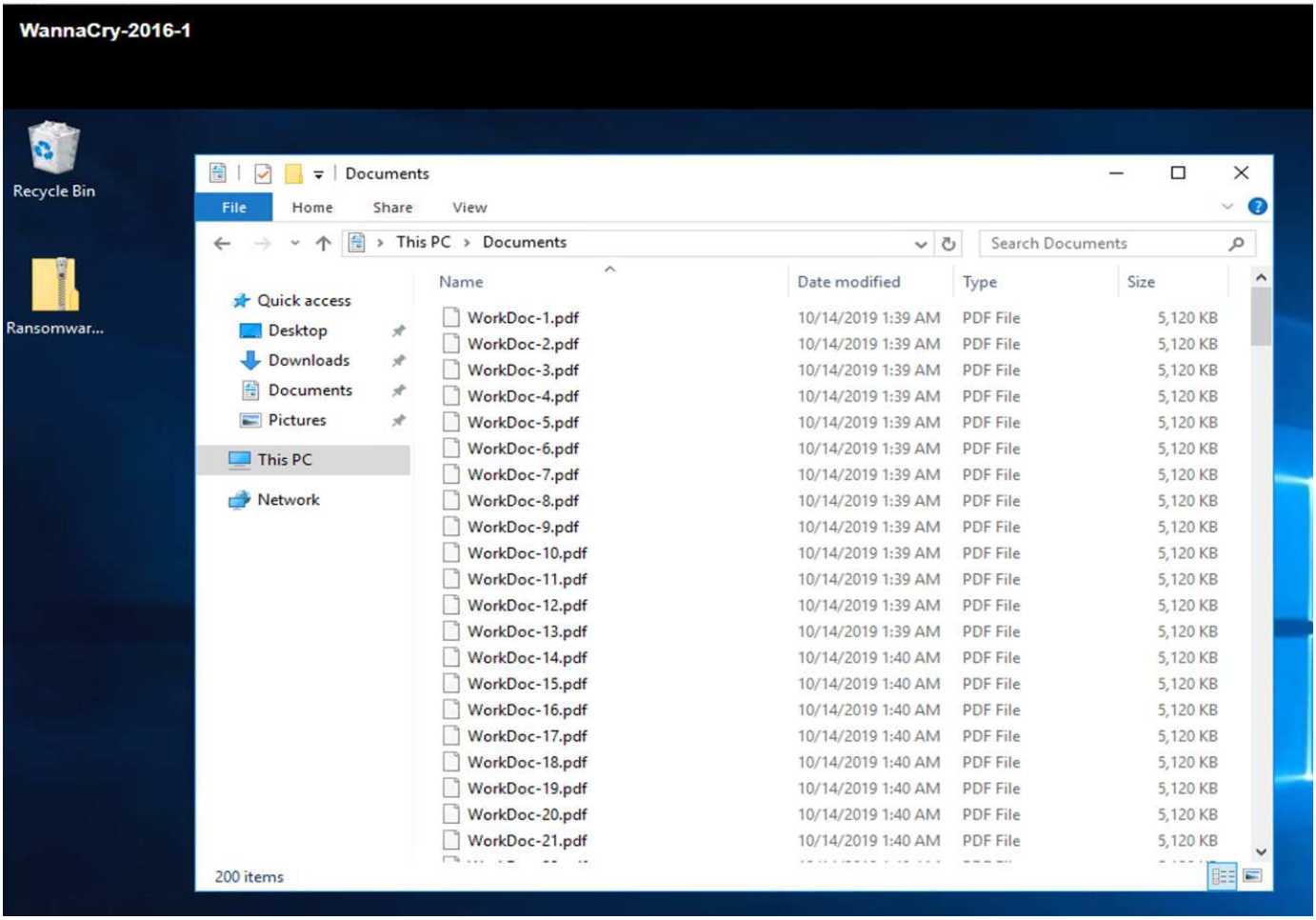
為了展示FlexPod 不偵測、補救和預防、測試平台是根據本文件撰寫時最新平台CVD所指定的準則而打造： "採用VMware vSphere 6.7 U1、Cisco UCS第4代及NetApp解決方案A系列CVD的資料中心FlexPod AFF"。

在ONTAP VMware vSphere基礎架構中部署了Windows 2016 VM、該VM提供來自NetApp VMware vCenter軟體的CIFS共用區。然後在CIFS共用區上設定NetApp FPolicy、以防止執行具有特定副檔名類型的檔案。NetApp SnapCenter 支援軟體也能管理基礎架構中VM的Snapshot複本、以提供應用程式一致的Snapshot複本。

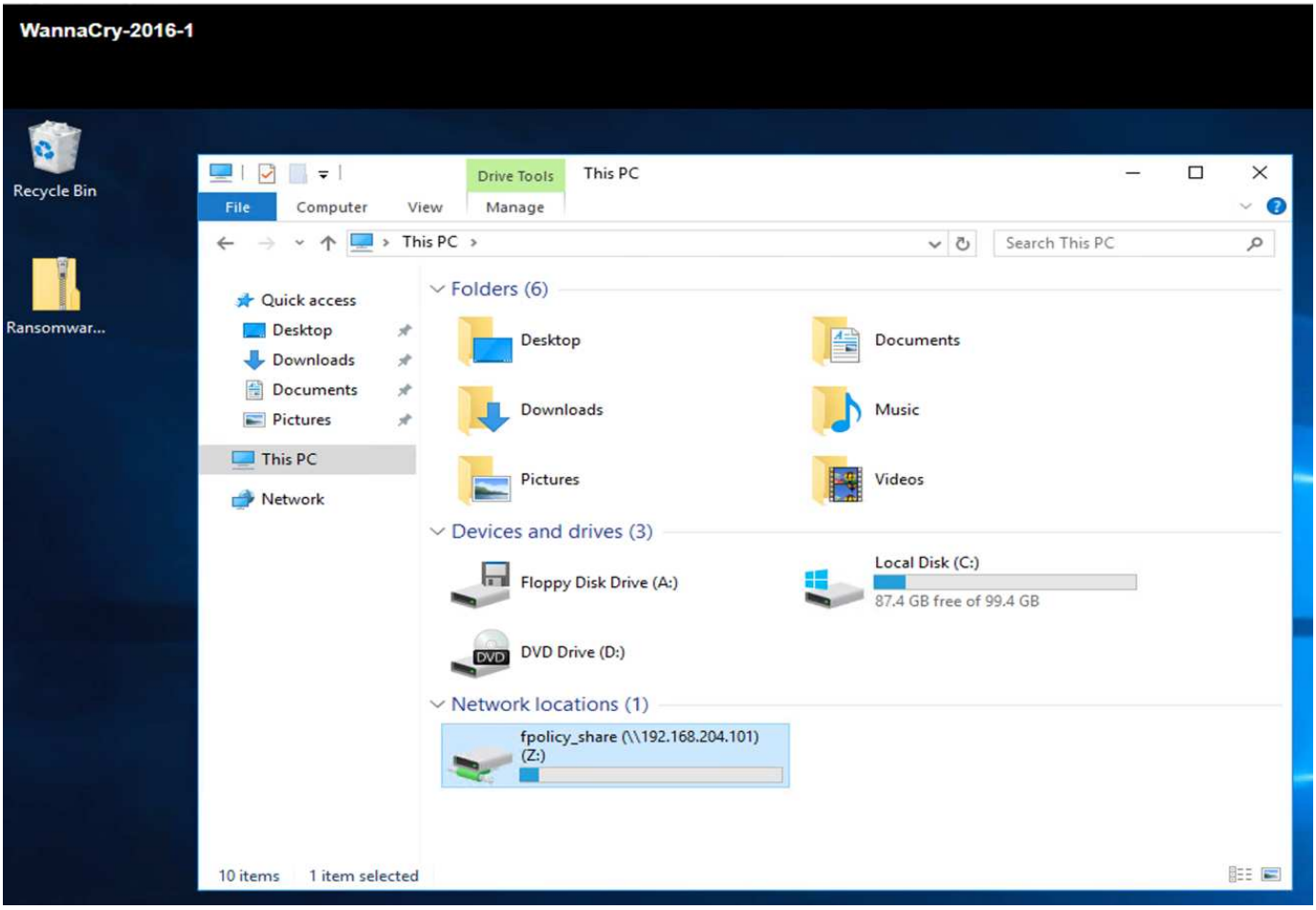
VM狀態及其檔案在攻擊之前

本節說明在攻擊VM之前的檔案狀態、以及對應到VM的CIFS共用區。

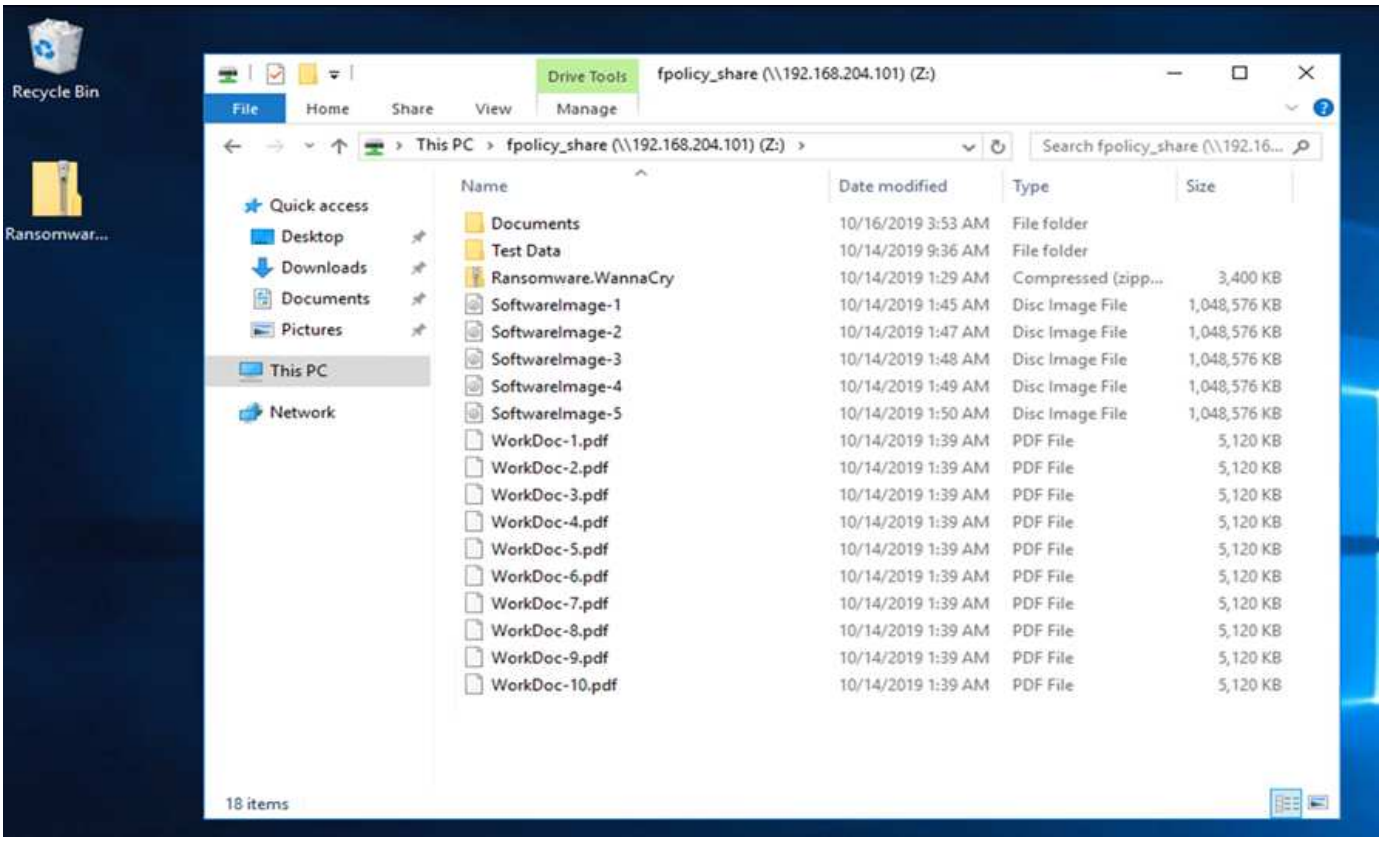
VM的「文件」資料夾中有一組尚未被WannaCry惡意軟體加密的PDF檔案。



下列螢幕快照顯示已對應至VM的CIFS共用區。



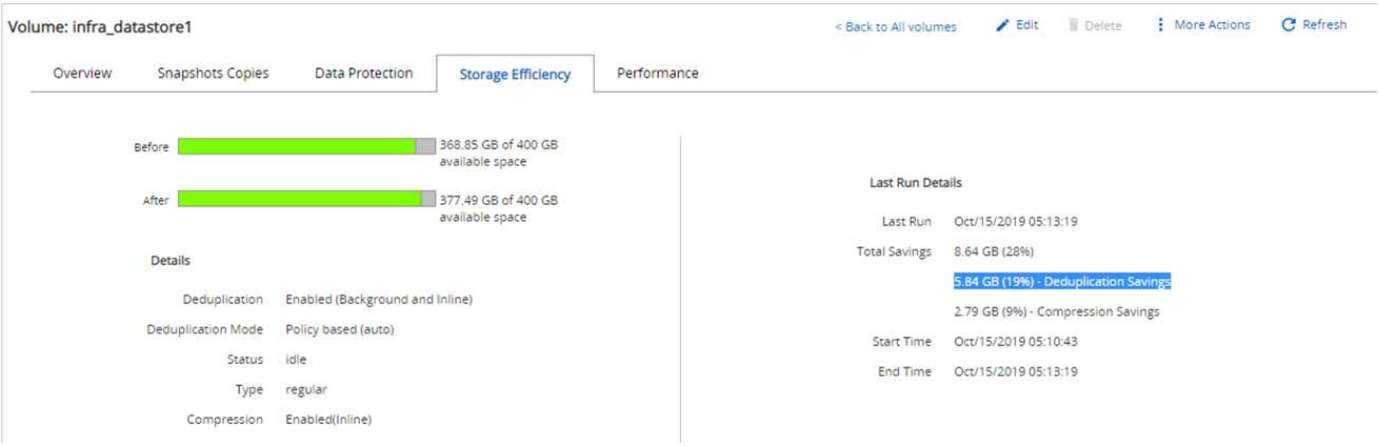
下列螢幕快照顯示CIFS共用區「fpolicy_share」上尚未被WannaCry惡意軟體加密的檔案。



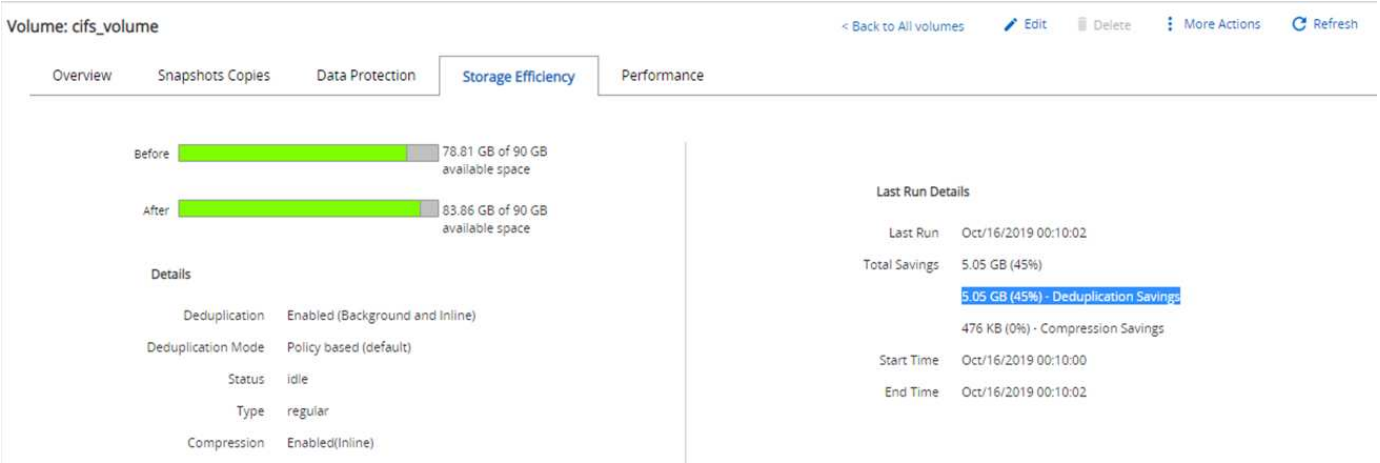
在攻擊之前提供重複資料刪除和**Snapshot**資訊

在攻擊之前、會指出Snapshot複本的儲存效率詳細資料和大小、並在偵測階段做為參考。

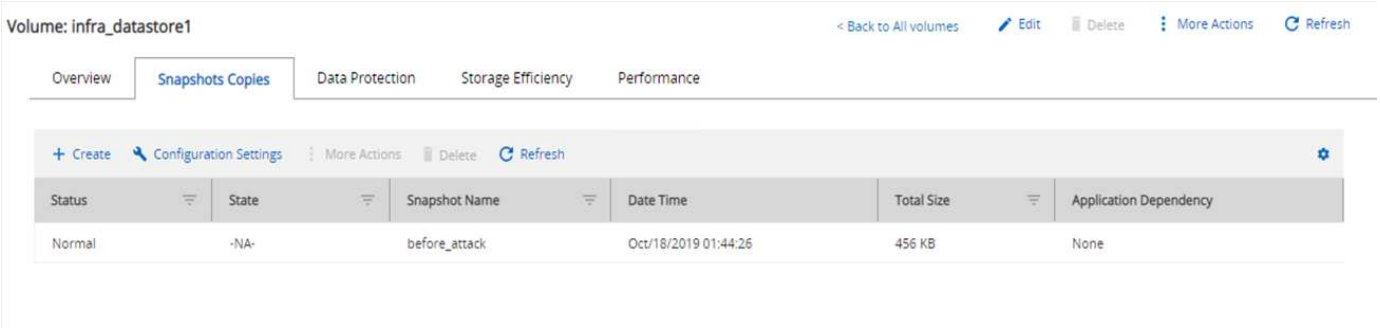
在託管VM的磁碟區上執行重複資料刪除技術、可節省19%的儲存空間。



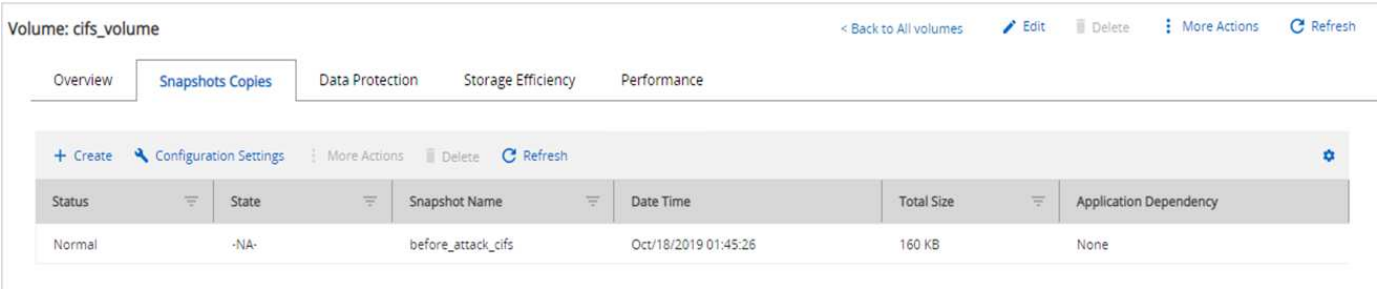
CIFS共用區「fpolicy_share'」上的重複資料刪除技術可節省45%的儲存空間。



針對裝載VM的磁碟區、觀察到Snapshot複本大小為456KB。



CIFS共用區的Snapshot複本大小為160KB。



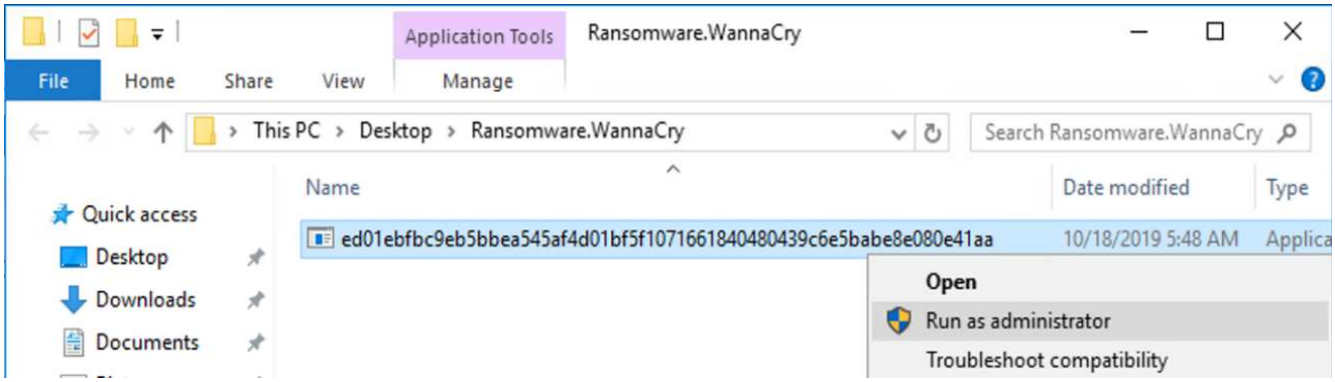
WannaCry感染VM和CIFS共用區

在本節中、我們將說明WannaCry惡意軟體是如何引進FlexPod 到這個環境、以及後續觀察到的系統變更。

下列步驟示範如何將WannaCry惡意軟體二進位檔引進VM：

1. 已擷取安全的惡意軟體。

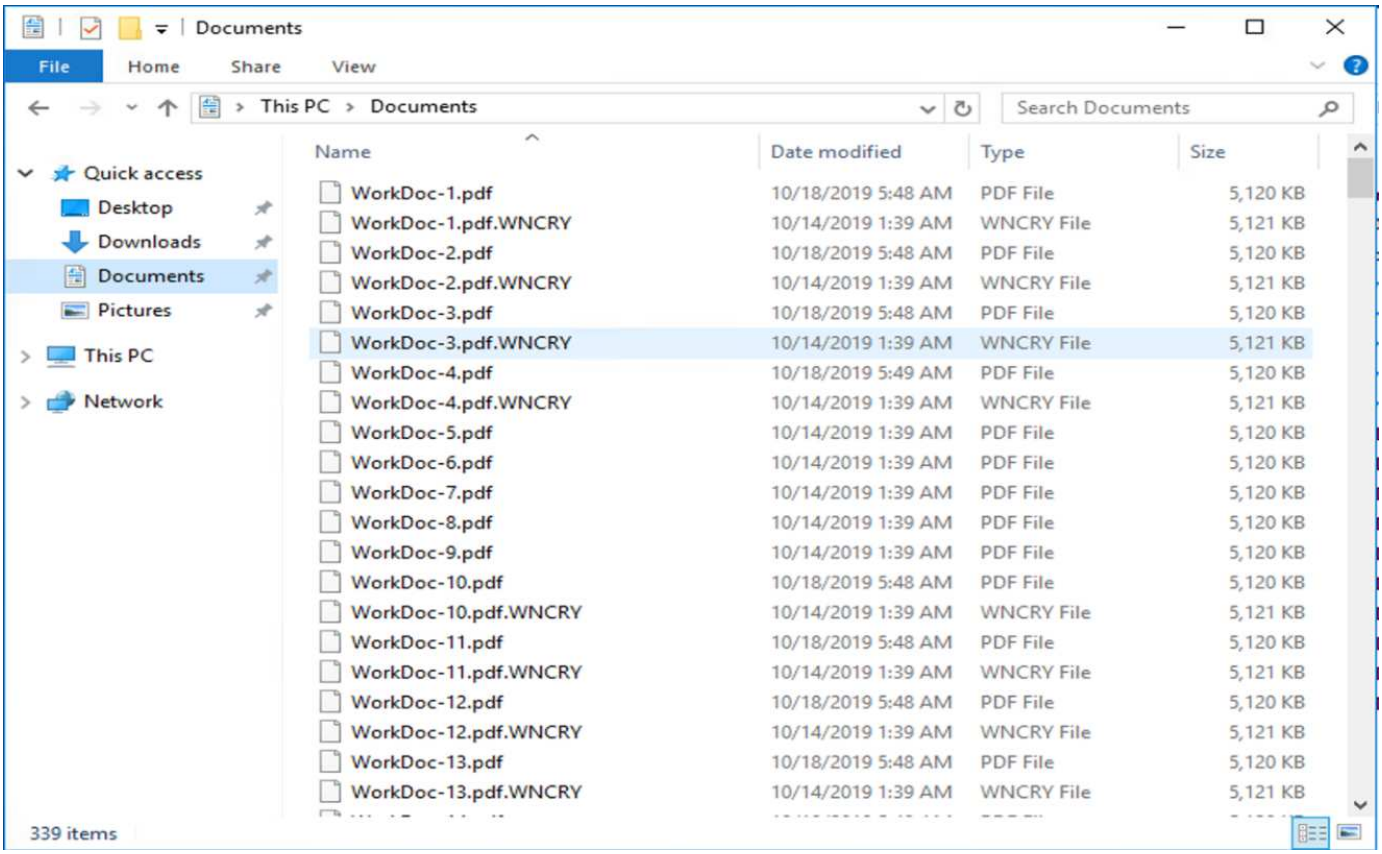
2. 執行二進位檔。



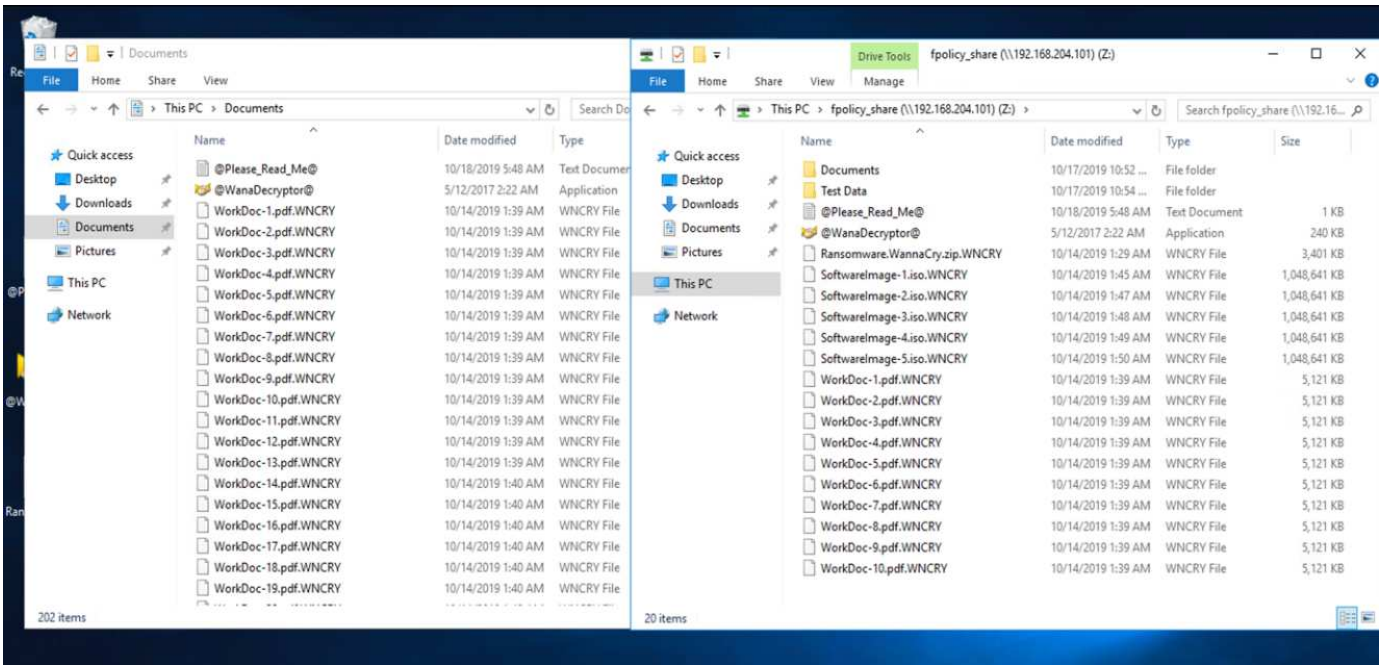
案例**1**：**WannaCry**會加密**VM**內的檔案系統及對應的**CIFS**共用區

WannaCry惡意軟體已加密本機檔案系統和對應的CIFS共用區。

惡意軟體開始使用WNCRY副檔名加密檔案。



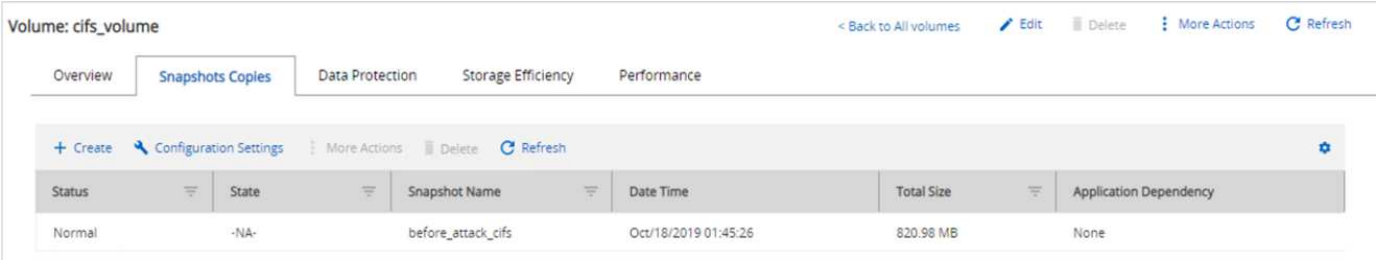
惡意軟體會加密本機VM和對應共用區中的所有檔案。



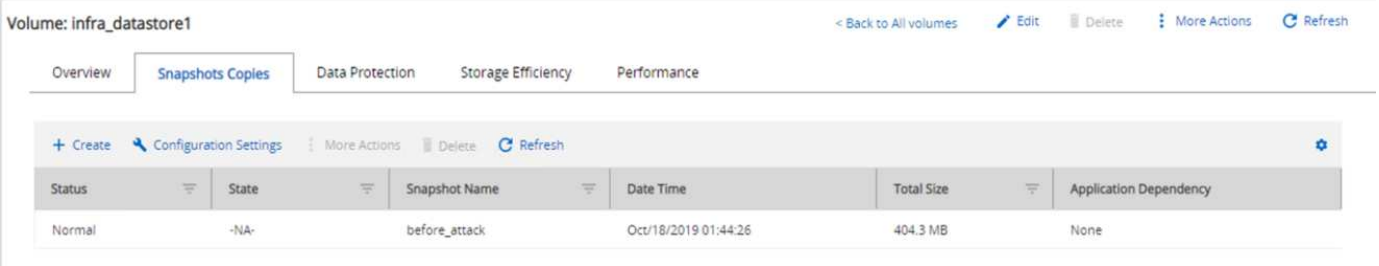
偵測

從惡意軟體開始加密檔案的那一刻起、它就引發Snapshot複本的大小呈指數式增加、儲存效率百分比呈指數式降低。

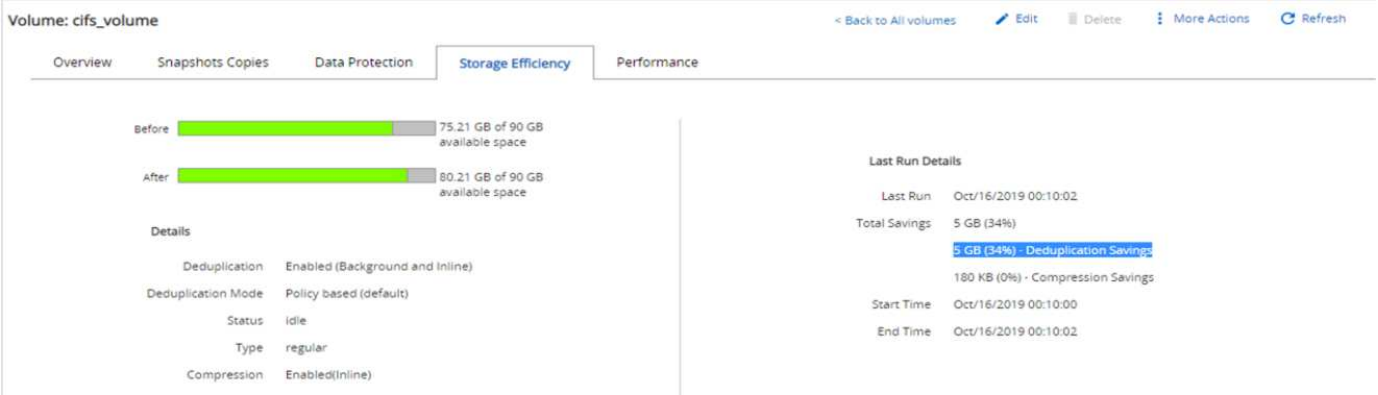
我們偵測到、在攻擊期間、託管CIFS共用區的磁碟區的Snapshot大小大幅增加至820.98MB。



我們偵測到裝載VM的磁碟區的Snapshot複本大小增加到404.3MB。



託管CIFS共享區的Volume儲存效率降低至34%。



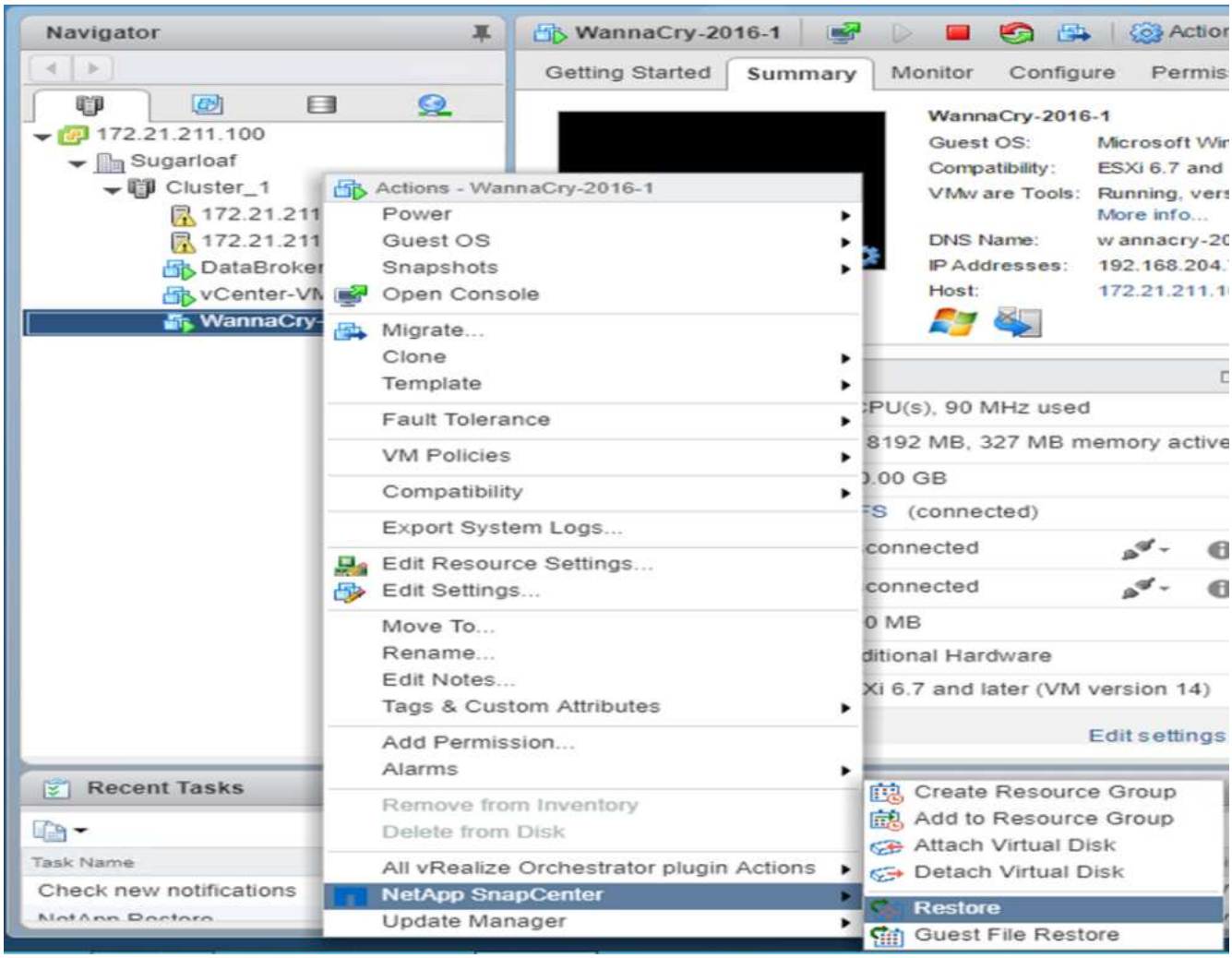
補救

使用攻擊前建立的全新Snapshot複本、還原VM和對應的CIFS共用區。

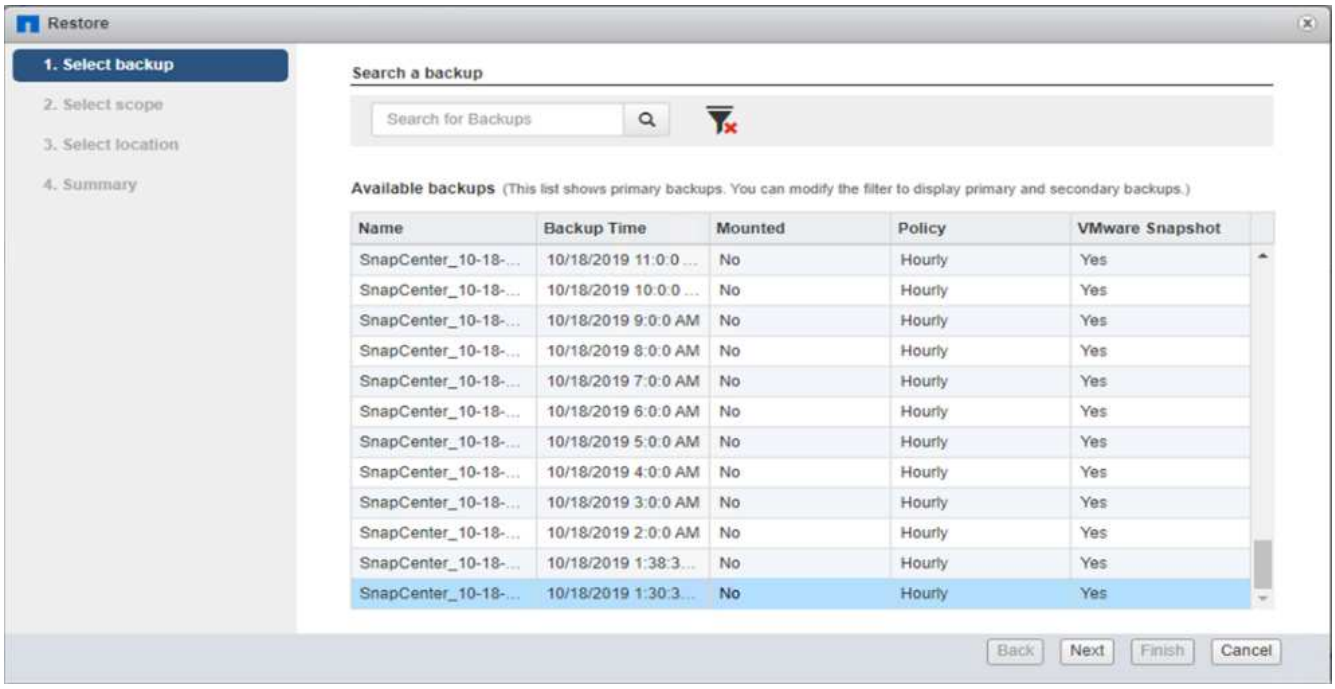
還原**VM**

若要還原VM、請完成下列步驟：

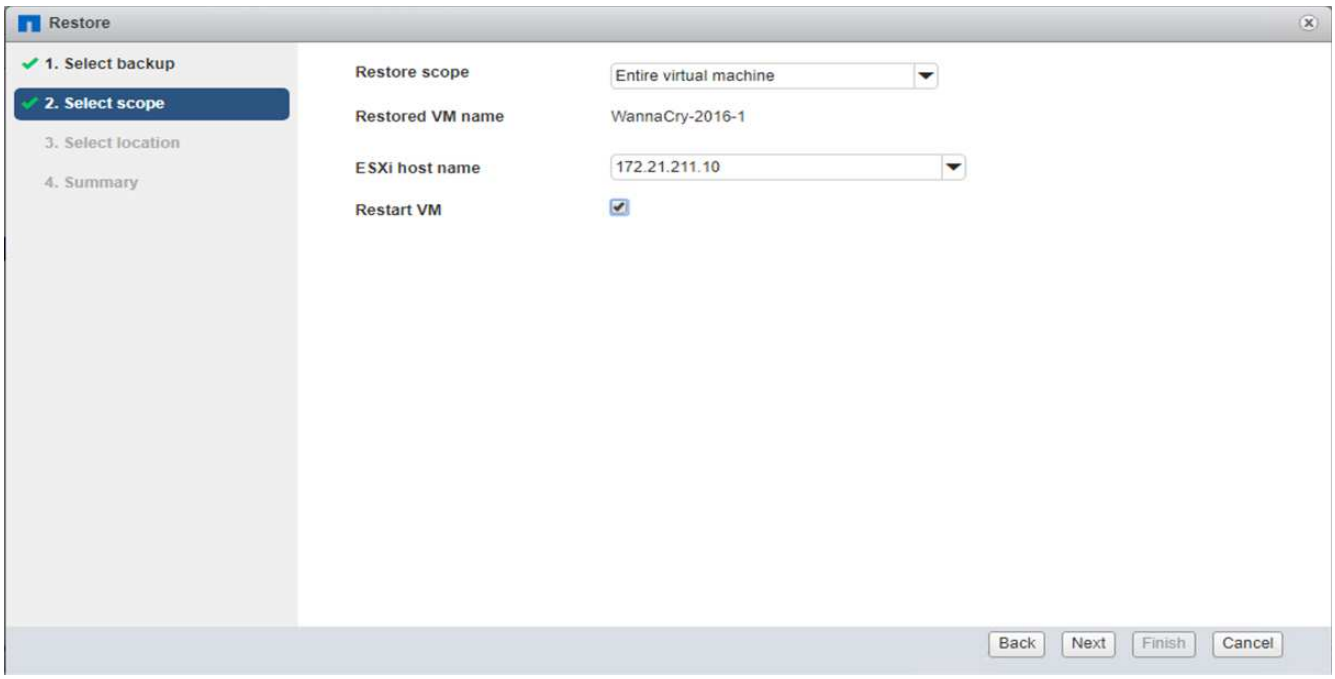
1. 使用SnapCenter 您使用NetApp建立的Snapshot複本來還原VM。



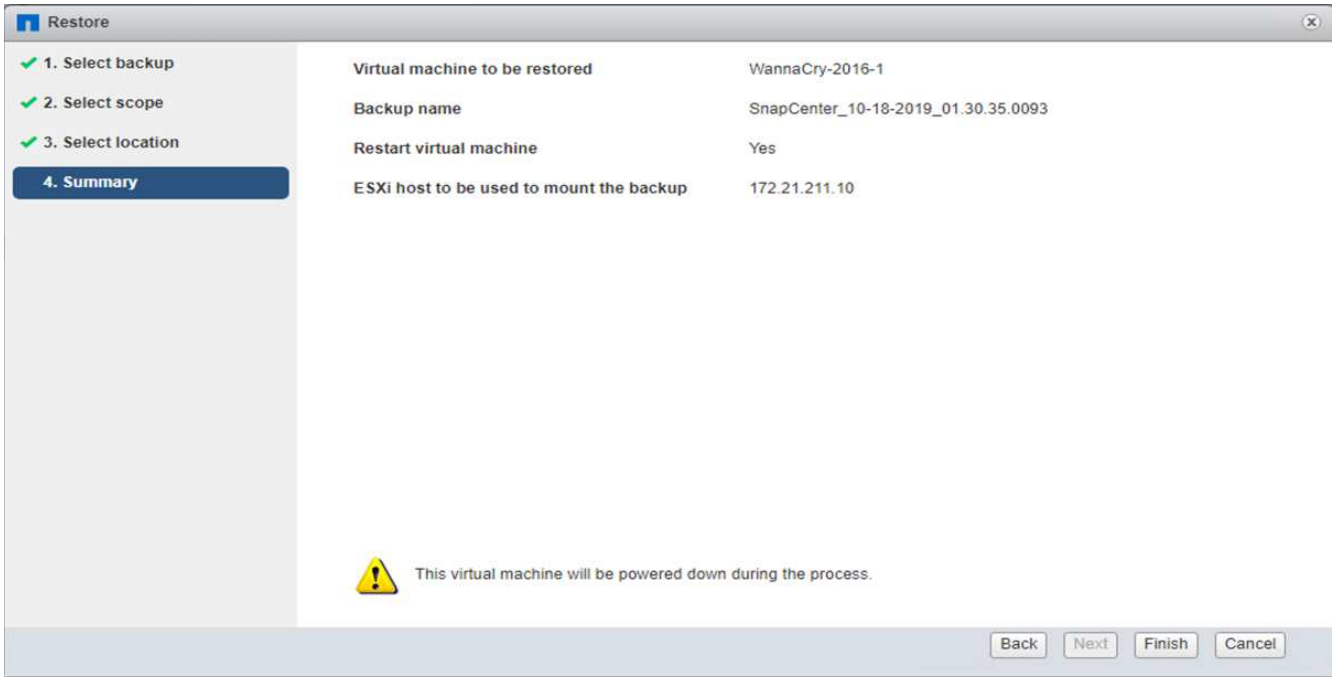
2. 選取所需的VMware一致Snapshot複本進行還原。



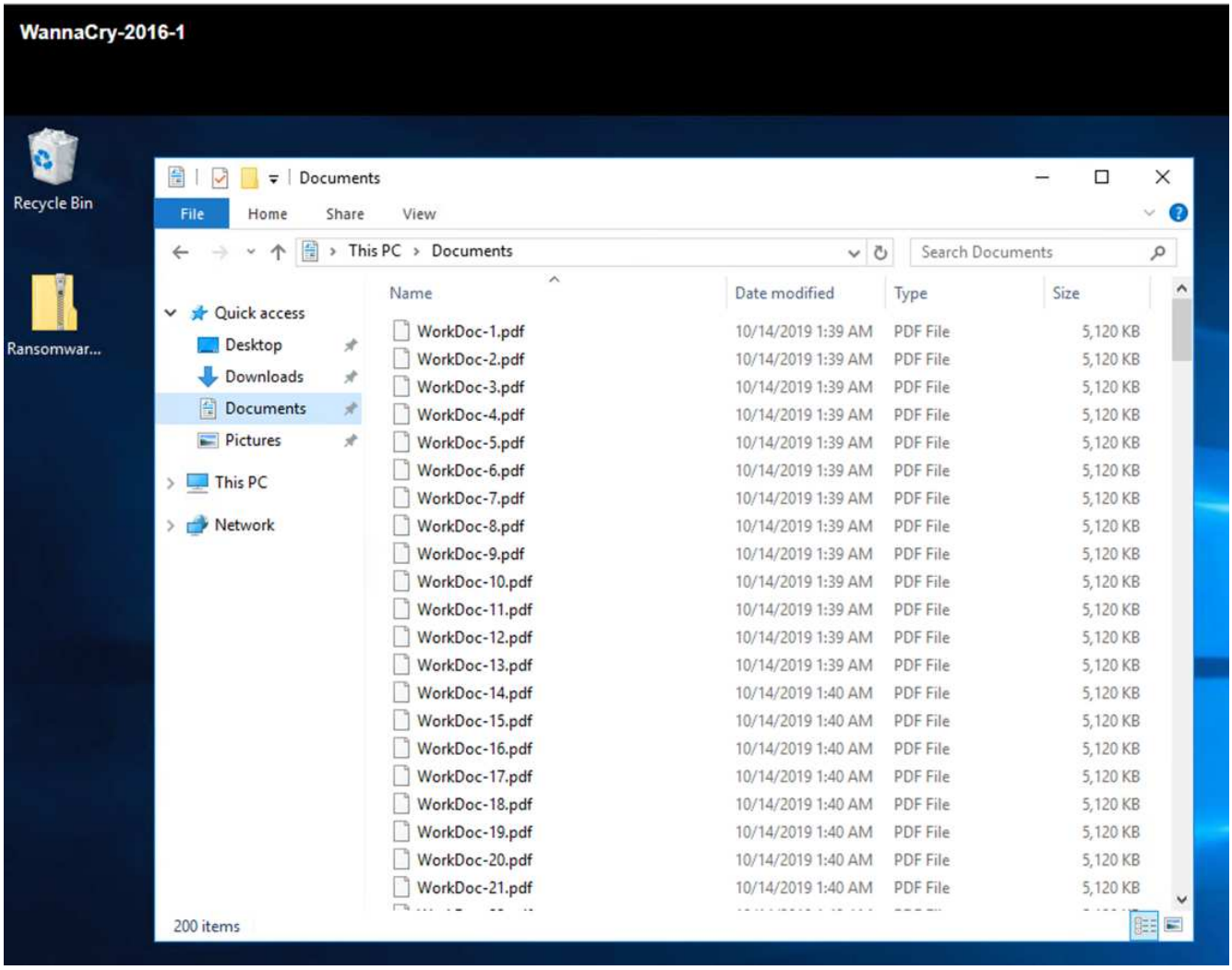
3. 整個VM都會還原並重新啟動。



4. 按一下「Finish（完成）」以開始還原程序。



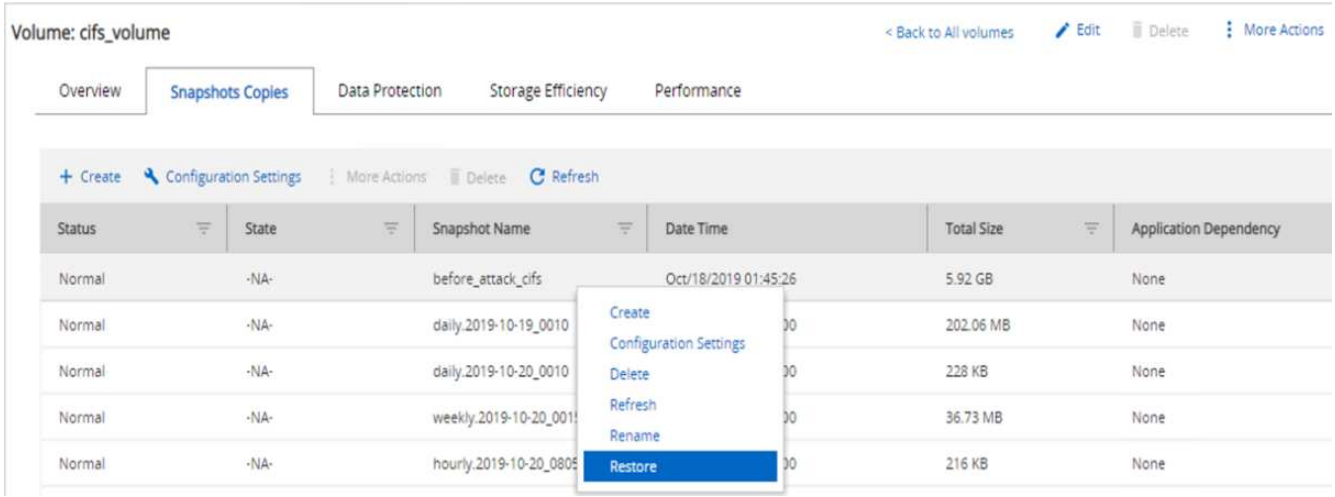
5. VM及其檔案將會還原。



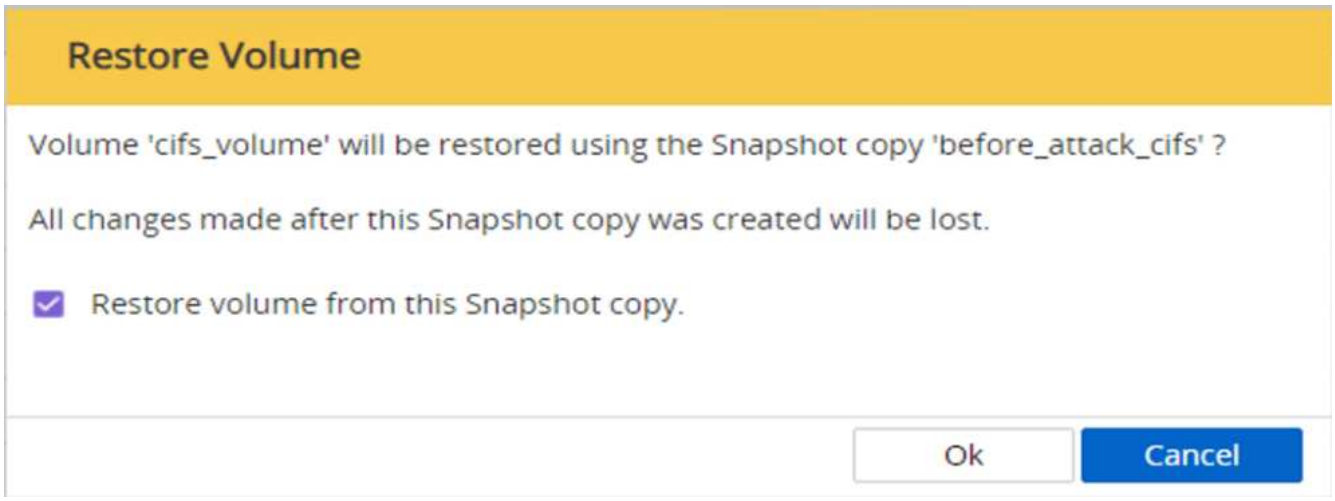
還原**CIFS**共用

若要還原CIFS共用區、請完成下列步驟：

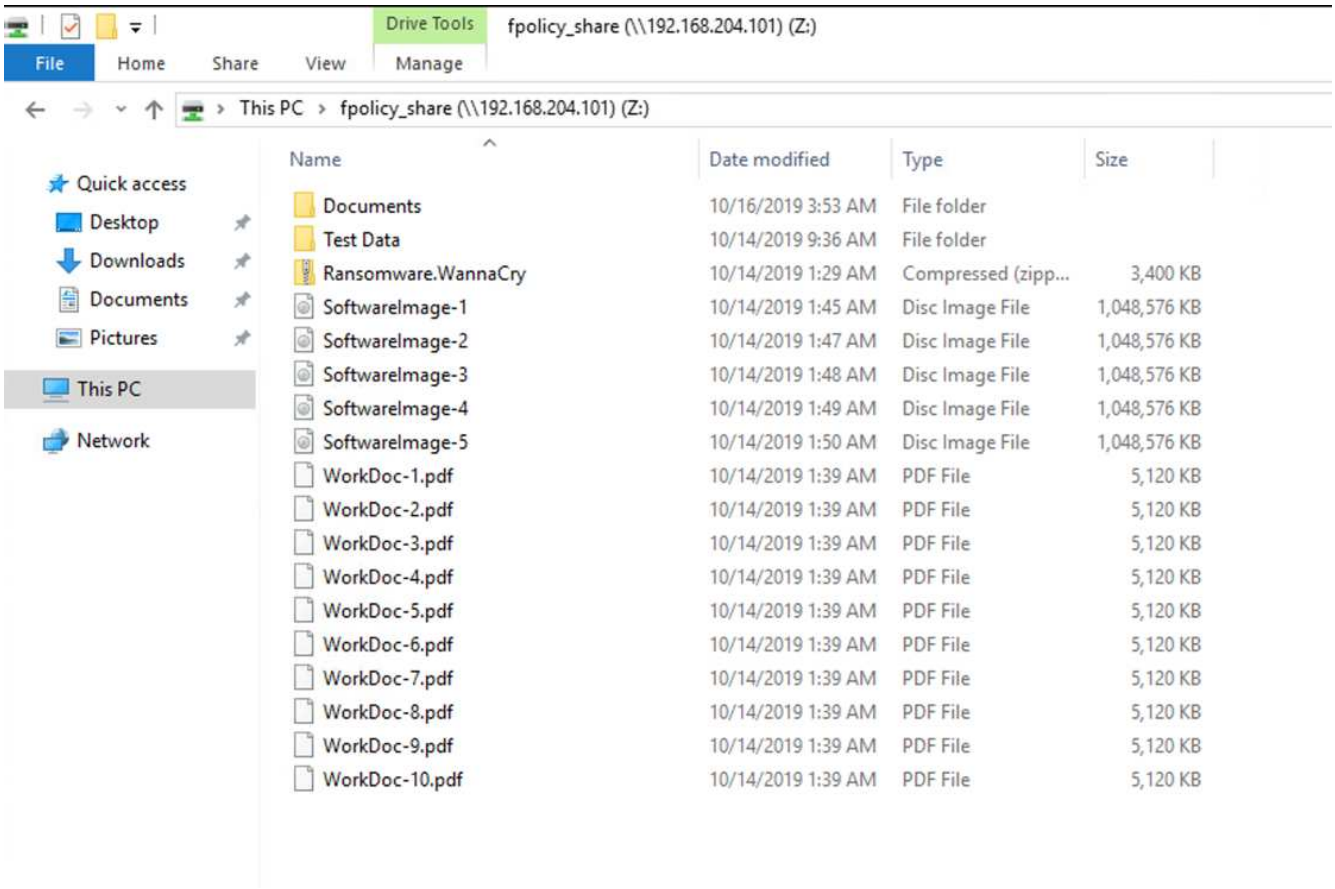
1. 使用攻擊前所取得磁碟區的Snapshot複本來還原共用區。



2. 按一下「確定」以啟動還原作業。



3. 還原後檢視CIFS共用區。



案例2：WannaCry會加密VM內的檔案系統、並嘗試加密透過FPolicy保護的對應CIFS共用

預防

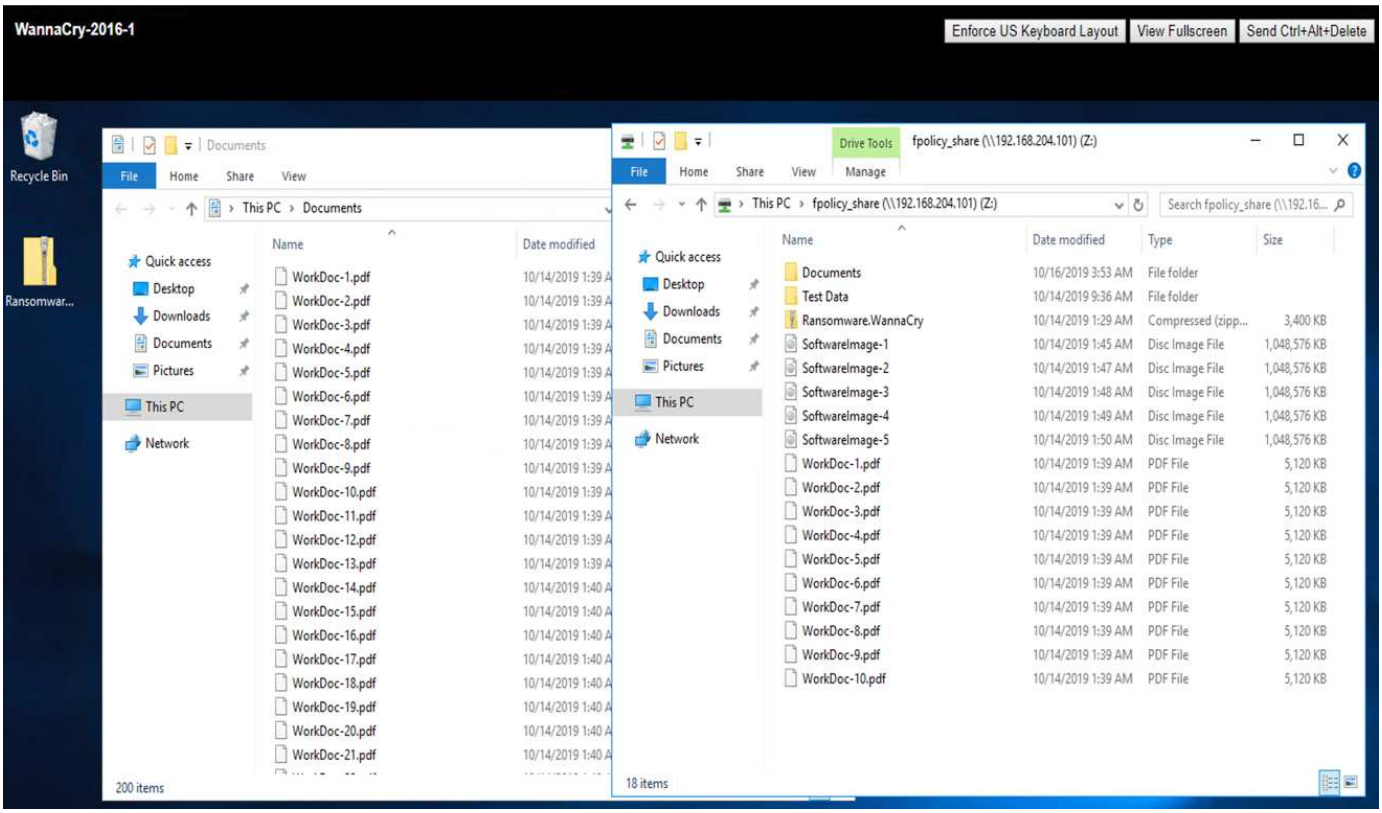
設定FPolicy

若要在CIFS共用區上設定FPolicy、請在ONTAP Windows叢集上執行下列命令：

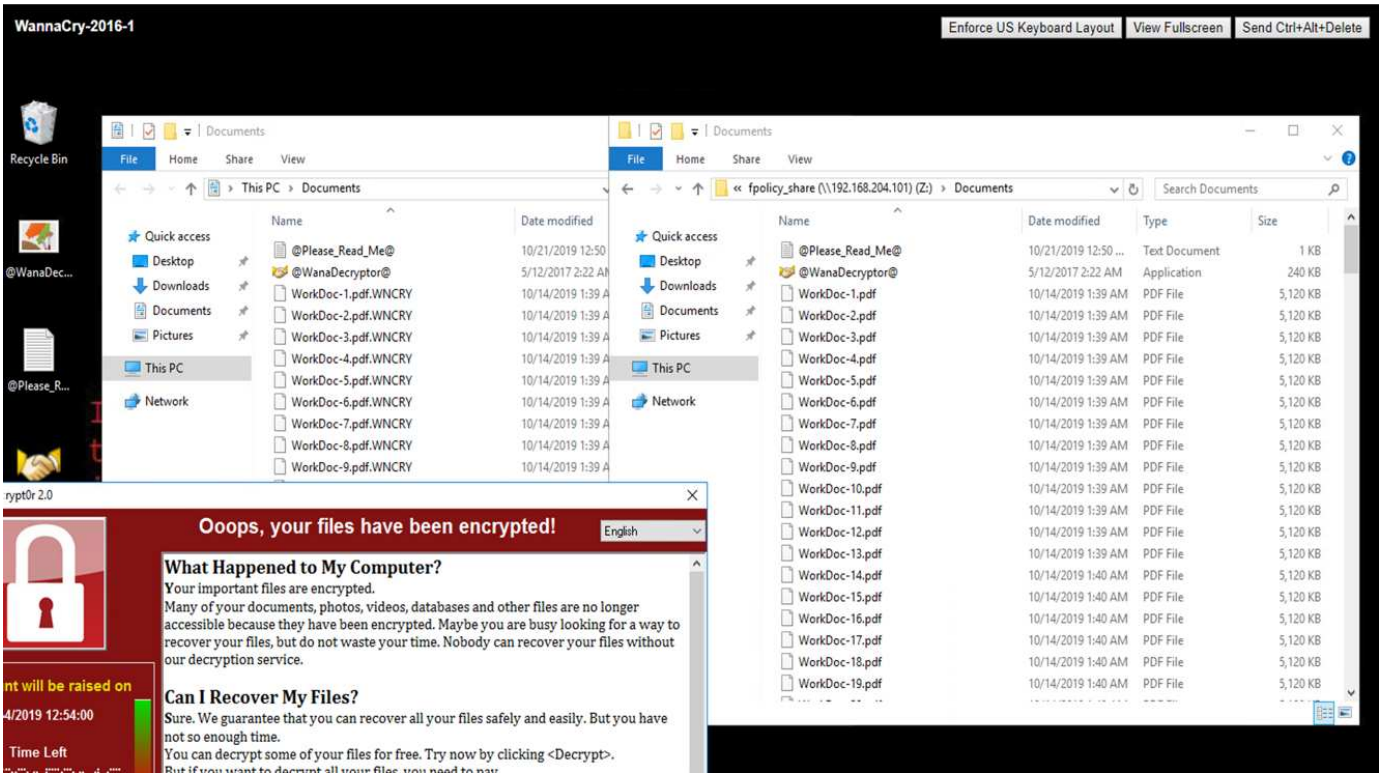
```
vserver fpolicy policy event create -vserver infra_svm -event-name
Ransomware_event -protocol cifs -file-operations create,rename,write,open
vserver fpolicy policy create -vserver infra_svm -policy-name
Ransomware_policy -events Ransomware_event -engine native
vserver fpolicy policy scope create -vserver infra_svm -policy-name
Ransomware_policy -shares-to-include fpolicy_share -file-extensions-to
-include WNCRY,Locky,ad4c
vserver fpolicy enable -vserver infra_svm -policy-name Ransomware_policy
-sequence-number 1
```

使用此原則時、不允許副檔名為WNCRY、Locky和ad4c的檔案執行建立、重新命名、寫入或開啟的檔案作業。

在遭受攻擊之前檢視檔案狀態、這些檔案未加密且位於乾淨的系統中。



VM上的檔案已加密。WannaCry惡意軟體嘗試加密CIFS共用區中的檔案、但FPolicy可防止其影響檔案。



無需支付贖金即可繼續營運

本文件所述的NetApp功能可協助您在攻擊發生後數分鐘內還原資料、並防止攻擊發生、讓您不受阻礙地繼續營運。

您可以設定Snapshot複本排程、以符合所需的恢復點目標（RPO）。Snapshot複製型還原作業非常快速、因此恢復時間目標（RTO）非常低。

最重要的是、您不需要支付任何攻擊所造成的贖金、也能迅速恢復正常營運。

結論

勒索軟體是有組織犯罪的產物、攻擊者的行為不符合道德規範。即使收到贖金、他們也可能不提供解密金鑰。受害者不僅遺失資料、也會損失大量金錢、並會面臨與生產資料遺失有關的後果。

根據A "Forbes文章"、只有19%的勒索軟體受害者在支付贖金後才取得資料。因此、作者建議在發生攻擊時不要支付贖金、因為這樣做可強化攻擊者對其商業模式的信心。

資料備份與還原作業是勒索軟體還原的重要部分。因此、必須將其納入業務規劃的一部分。這些作業的實作應列入預算、以便在發生攻擊時、恢復功能不會受到影響。

關鍵在於在這段旅程中選擇正確的技術合作夥伴、FlexPod 而在All Flash FAS 更新的系統中、無需額外成本、即可在原生環境中提供大部分所需的功能。

感謝

作者感謝下列人士對建立本文件的支持：

- NetApp公司的豪爾赫·高梅茲·納瓦雷特
- NetApp的Gannesh Kamath

其他資訊

若要深入瞭解本文所述資訊、請檢閱下列文件和 / 或網站：

- NetApp Snapshot軟體

  "https://www.netapp.com/us/products/platform-os/snapshot.aspx"

- 還原備份管理SnapCenter

  "https://www.netapp.com/us/products/backup-recovery/snapcenter-backup-management.aspx"

- 資料法規遵循SnapLock

  "https://www.netapp.com/us/products/backup-recovery/snaplock-compliance.aspx"

- NetApp 產品文件

  "https://www.netapp.com/us/documentation/index.aspx"

- Cisco進階惡意軟體保護（AMP）

  "https://www.cisco.com/c/en/us/products/security/advanced-malware-protection/index.html"

- Cisco Stealthwatch

  "https://www.cisco.com/c/en_in/products/security/stealthwatch/index.html"

Copyright Information

Copyright © 2022 NetApp, Inc. All rights reserved. Printed in the U.S. No part of this document covered by copyright may be reproduced in any form or by any means-graphic, electronic, or mechanical, including photocopying, recording, taping, or storage in an electronic retrieval system-without prior written permission of the copyright owner.

Software derived from copyrighted NetApp material is subject to the following license and disclaimer:

THIS SOFTWARE IS PROVIDED BY NETAPP “AS IS” AND WITHOUT ANY EXPRESS OR IMPLIED WARRANTIES, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE, WHICH ARE HEREBY DISCLAIMED. IN NO EVENT SHALL NETAPP BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

NetApp reserves the right to change any products described herein at any time, and without notice. NetApp assumes no responsibility or liability arising from the use of products described herein, except as expressly agreed to in writing by NetApp. The use or purchase of this product does not convey a license under any patent rights, trademark rights, or any other intellectual property rights of NetApp.

The product described in this manual may be protected by one or more U.S. patents, foreign patents, or pending applications.

RESTRICTED RIGHTS LEGEND: Use, duplication, or disclosure by the government is subject to restrictions as set forth in subparagraph (c)(1)(ii) of the Rights in Technical Data and Computer Software clause at DFARS 252.277-7103 (October 1988) and FAR 52-227-19 (June 1987).

Trademark Information

NETAPP, the NETAPP logo, and the marks listed at http://www.netapp.com/TM are trademarks of NetApp, Inc. Other company and product names may be trademarks of their respective owners.